

Industrial Security (Bachelor)

Exercise Sheet – Section 08

Defense in Depth

Exercise 8.1 – Layered Control Design

Scenario: *a malicious USB stick is inserted into an engineering workstation by a contractor.*

1. List every defense-in-depth control that could break this attack chain.
2. Aim for at least eight controls across at least four layers (physical, host, network, monitoring, identity, policy).
3. Mark each control as *Preventive*, *Detective*, or *Corrective*.

Exercise 8.2 – Lab: Application Whitelisting

On a Windows VM acting as an HMI:

1. Configure AppLocker with default rules.
2. Add a publisher rule allowing your chosen HMI runtime.
3. Attempt to run a downloaded `.exe` and a PowerShell script.
4. Document the AppLocker audit log entries and the user experience.

Exercise 8.3 – Lab: OT IDS

See `labs/lab-06-ids`.

1. Deploy Malcolm or Zeek on a Linux VM.
2. Mirror the OpenPLC traffic to it.
3. Generate baseline traffic for ~30 minutes.
4. Launch the Modbus injection from Lab 02 and confirm the IDS surfaces it.
5. Tune one false positive to an acceptable level.

Exercise 8.4 – Remote-Access Pattern

Draw the secure-remote-access pattern for a vendor that needs to update a PLC in your plant once a quarter. Label every component, indicate where MFA happens, where the session is recorded, and where the operator approves. Identify two failure modes and how the design tolerates them.